OWASP API Security Top 10
Um guia para a implementação de Back-Ends mais seguros

Renato Groffe
Microsoft MVP, Docker Captain, Grafana Champion, APIsec U Ambassador, MTAC
linkedin.com/in/renatogroffe
renatogroffe.medium.com

Microsoft® Most Valuable Professional

MTAC org.br

GRAFANA CHAMPIONS

APISEC UNIVERSITY AMBASSADOR

DEVPIRA

Renato Groffe

- Microsoft Most Valuable Professional (MVP)
- Docker Captain
- Grafana Champion
- APISEC U Ambassador
- Multi-Plataform Technical Audience Contributor (MTAC)
- Arquiteto de Soluções/Software
- +20 anos de experiência na área de Tecnologia
- Community Leader, Autor Técnico e Palestrante

Participe de nossas iniciativas gratuitas

- Eventos online e gratuitos
  https://www.meetup.com/dotnet-Sao-Paulo/

.NET SP

Certificações Gratuitas em Segurança

www.apisecuniversity.com/#courses

APISEC
UNIVERSITY

Conteúdos desta apresentação

Deixem um star ⭐ apoiando

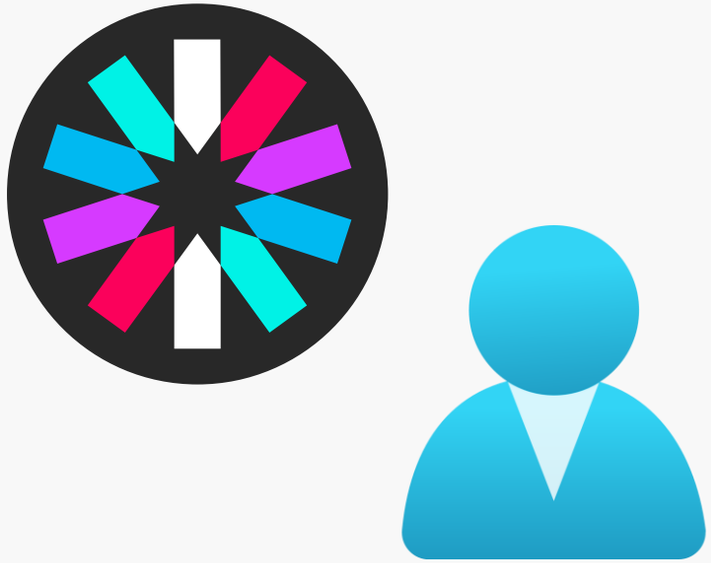
github.com/renatogroffe/owasp-api-top-10_devpira-security-wknd

Agenda

- Alguns conceitos importantes de segurança
- OWASP API Security Top 10: uma visão geral
- Certificações gratuitas na área
- Outras iniciativas OWASP importantes

Conceitos e pontos importantes

- Autenticação (identidade)
- Autorização (permissões)
- Tokens JWT



OWASP API Security Top 10: uma visão geral

- Última compilação realizada em **2023** pela **OWASP (Open Worldwide Application Security Project)**
- Vulnerabilidades mais comuns
- APIs são um elemento central nas mais variadas arquiteturas

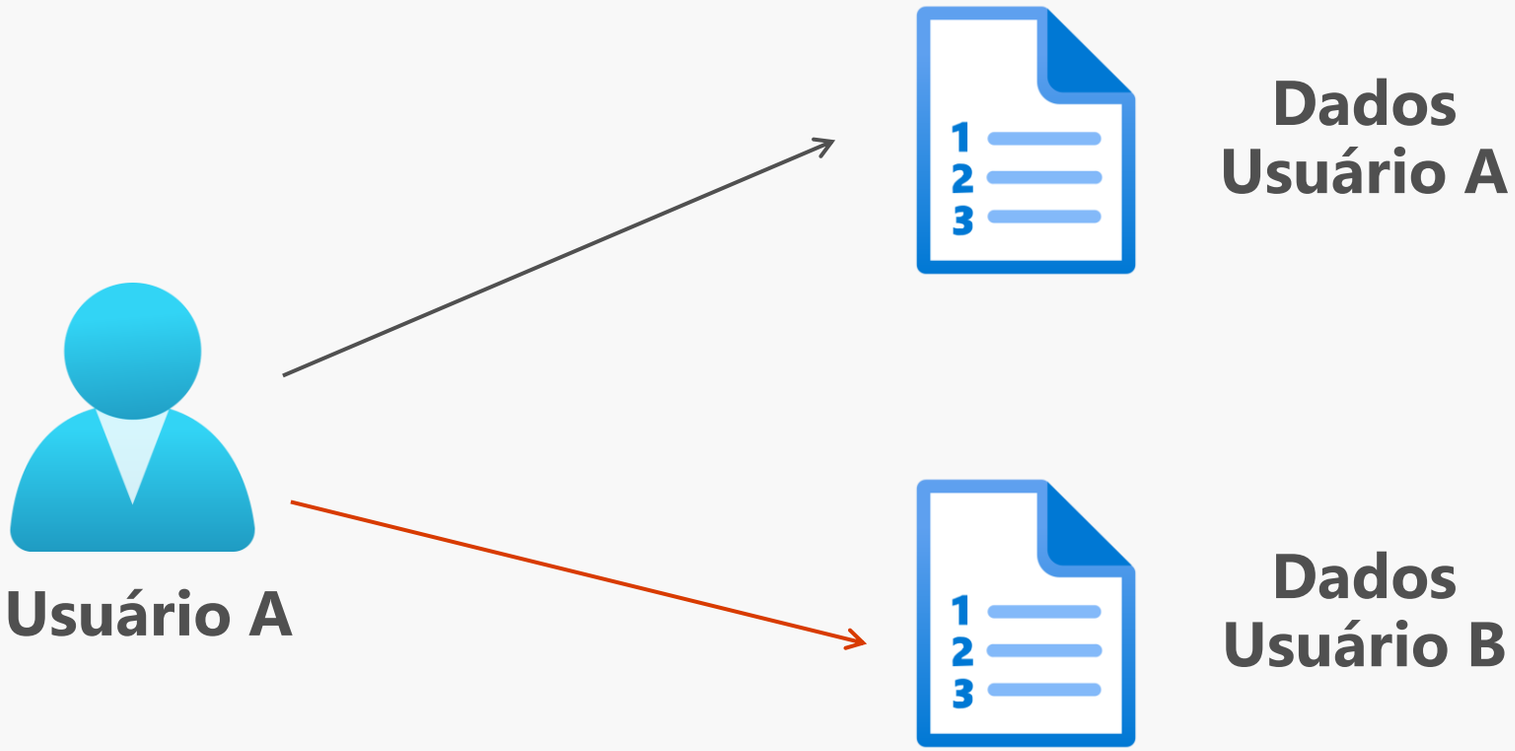
OWASP API Security Top 10: uma visão geral

- API1:2023 - Broken Object Level Authorization
- API2:2023 - Broken Authentication
- API3:2023 - Broken Object Property Level Authorization
- API4:2023 - Unrestricted Resource Consumption
- API5:2023 - Broken Function Level Authorization
- API6:2023 - Unrestricted Access to Sensitive Business Flows
- API7:2023 - Server Side Request Forgery
- API8:2023 - Security Misconfiguration
- API9:2023 - Improper Inventory Management
- API10:2023 - Unsafe Consumption of APIs

API1:2023 - Broken Object Level Authorization (BOLA)

- Acesso indevido a informações, utilizando IDs e outros dados que podem ser inferidos
- Definir níveis de acesso às informações
- Usar IDs gerados randomicamente

API1:2023 - Broken Object Level Authorization (BOLA)



API2:2023 - Broken Authentication

- Tokens de autenticação podem ser comprometidos através de manipulação dos dados
- Senhas fracas, credential stuffing
- JWT não envolve criptografia num payload (**base64**)

API3:2023 - Broken Object Property Level Authorization (BOPLA)

- Exposição de dados em excesso
- Dados sensíveis
- Possibilidade de edição de dados sensíveis (senha, dados pessoais, documentos)
- Falta de melhores controles de autenticação/autorização

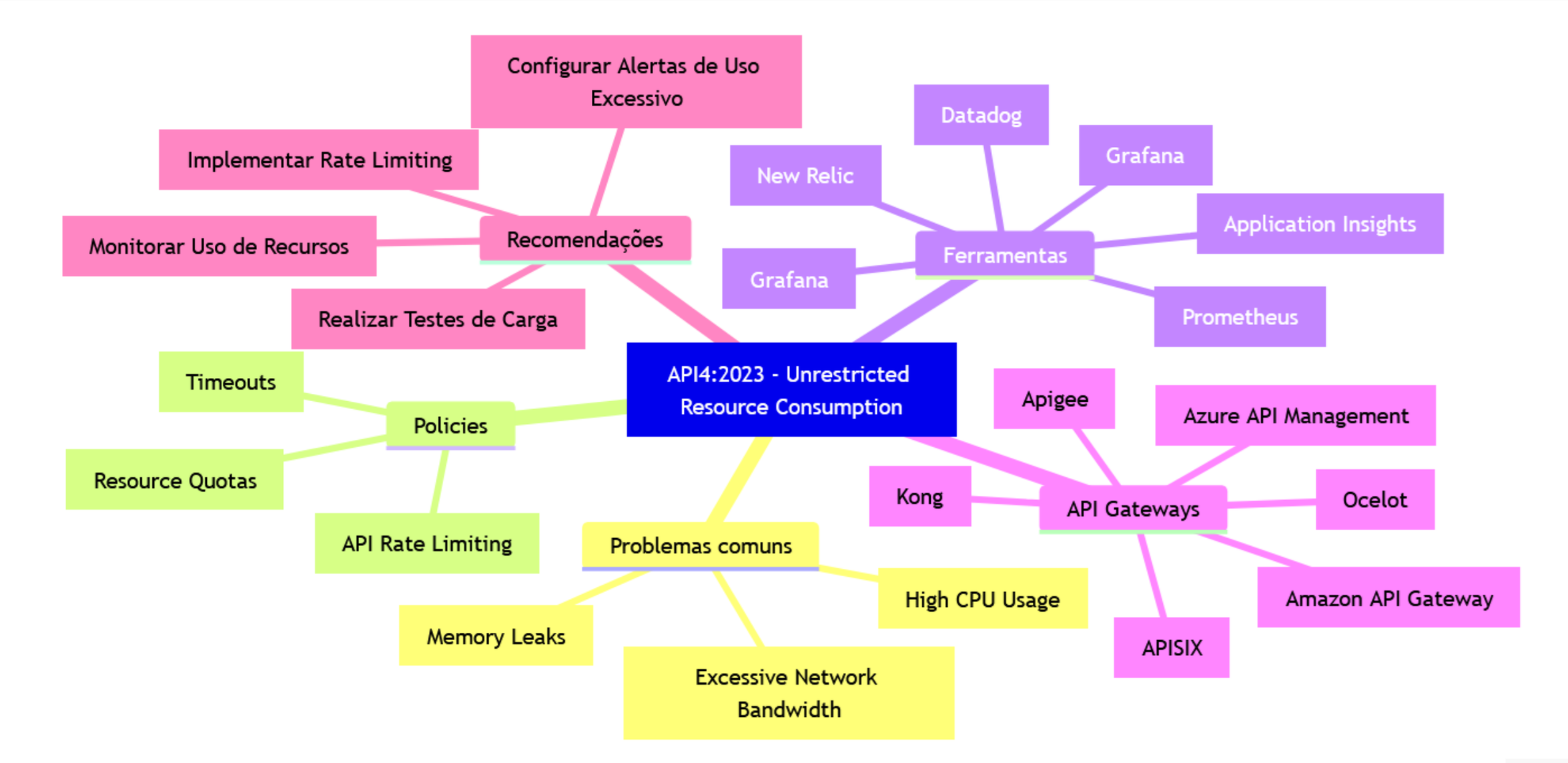
API4:2023 - Unrestricted Resource Consumption

- Uso de APIs sem restrições e até a exaustão de recursos
- Denial of Service
- Degradação de performance

API4:2023 - Unrestricted Resource Consumption

- APIs Gateways com policies limitando uso de APIs
- Rate Limit
- Erro 429 (Too many requests)
- Azure API Management, Kong...

API4:2023 - Unrestricted Resource Consumption



API5:2023 - Broken Function Level Authorization (BFLA)

- Capacidade do Usuário A executar transações em nome do Usuário B
- BOLA (visualização de dados) x BFLA (transações)
- Cuidados expondo endpoints do tipo POST, PUT, DELETE ou de funções administrativas
- Definir controles de autorização claros

API6:2023 - Unrestricted Access to Sensitive Business Flows

- Ataques direcionados a APIs que fazem parte de um fluxo específico do negócio
- Comprometer operações
- Limitar o acesso a APIs críticas
- Instrumentação/Observabilidade, analisando tráfegos anormais

API7:2023 Server Side Request Forgery (SSRF)

- URLs informadas por um consumidor podem levar a eventuais ataques
- Validar dados fornecidos
- Evitar redirecionamentos via HTTP

API7:2023 Server Side Request Forgery (SSRF)

- Uma tentativa de port scanning…

```
POST /api/profile/upload_picture

{
  "picture_url": "http://example.com/profile_pic.jpg"
}
```

```
{
  "picture_url": "localhost:8080"
}
```

API8:2023 - Security Misconfiguration

- Cuidados com o que for manipulado via Header
- Evitar o uso de contas default
- Evitar mensagens de erro “verbosas”
- Necessidade de implementar CORS (Cross-Origin Resource Sharing)

API8:2023 - Security Misconfiguration

- Não libere o uso de métodos HTTP desnecessários para um endpoint
- Falta de um melhor tratamento de dados de Input
- Forçar o tráfego de dados em formato encriptado

API9:2023 - Improper Inventory Management

- Endpoints de versões antigas podem permanecer disponíveis
- Constituem brechas para outros tipos de ataque
- Cuidados com o que será exposto via OpenAPI
- APIOps e API Gateways contribuem para uma melhor governança

API10:2023 - Unsafe Consumption of APIs

- Integrações sempre estão presentes em projetos corporativos
- APIs de terceiros podem ser uma porta de entrada para ataques
- Garantir que boas práticas de segurança são também adotadas por parceiros e fornecedores

Certificações Gratuitas em Segurança

www.apisecuniversity.com/#courses

APISEC
UNIVERSITY

Certificações Gratuitas em Cibersegurança

https://www.linuxfoundation.org/

THE LINUX FOUNDATION

Outras iniciativas OWASP importantes

- OWASP Top 10:2025
- OWASP MCP Top 10
- OWASP Cheat Sheet Series
- OWASP Top 10 for Large Language Model Applications

Software Supply Chain Failures

- 3ª vulnerabilidade OWASP Top 10:2025
- Cuidados com pacotes NuGet, npm…
- Imagens Docker
- Soluções SAST para scan de packages
- Docker Hardened Images

Conteúdos desta apresentação

Deixem um star ⭐ apoiando

github.com/renatogroffe/owasp-api-top-10_devpira-security-wknd

OBRIGADO!